



Security Audit Report

cMATRA Token Merger Portal

Prepared for: Flux Point Studios

Date: April 14, 2026

Version: 1.0

Classification: Public

Scope: Merger portal web application, backend services, on-chain validator

ALL FINDINGS REMEDIATED

1. Executive Summary

A comprehensive security audit was conducted on the cMATRA Token Merger Portal — the web application through which holders of eligible legacy Cardano assets (AGENT, SHARDS, and five NFT collections) surrender those assets in exchange for cMATRA at fixed, published redemption rates. The audit covered the full technology stack: the user-facing frontend, server-side API layer, backend transaction-building service, and the on-chain Plutus V3 smart contract (Aiken).

Six findings were identified across critical, high, and medium severity levels. All six have been fully remediated and verified prior to the publication of this report. No outstanding vulnerabilities remain at the time of writing.

Overall Assessment: The cMATRA Merger Portal is ready for public launch. The on-chain validator enforces authorization and time-based access control. The backend service implements defense-in-depth with authenticated endpoints, transaction tracking, strict input validation, and rate limiting. The frontend provides clear, irreversible-action safeguards for users.

2. Scope & Methodology

2.1 Components Audited

Component	Technology	Description
Frontend Portal	Next.js / React / TypeScript	Password-gated single-page application with CIP-30 wallet integration
API Proxy Layer	Next.js API Routes	Server-side routes that mediate between frontend and backend service
Transaction Service	Python / FastAPI / pycardano	Builds and co-signs surrender transactions; manages pool UTxO selection
On-Chain Validator	Aiken (Plutus V3)	Parameterized spend validator enforcing authorization and time-lock
Rate & Config Layer	TypeScript / Python	Fixed rate table, asset registry, and redemption computation

2.2 Methodology

The audit followed a threat-model-driven approach:

1. **Attack surface mapping** — identified all entry points, data flows, trust boundaries, and privileged operations across the full stack.
2. **Cardano-specific analysis** — reviewed the Aiken validator for common Plutus vulnerabilities (double satisfaction, datum hijacking, redeemer confusion, value preservation, time-lock bypass).
3. **Web application analysis** — evaluated API routes for injection, authentication bypass, information disclosure, rate-limit evasion, and CORS misconfiguration.
4. **Co-signing flow analysis** — traced the two-party transaction lifecycle for CBOR manipulation, replay attacks, and signature scope issues.
5. **Remediation and verification** — all findings were fixed in code, type-checked, and retested before this report was finalized.

3. Findings Summary

#	Severity	Finding	Category	Status
1	Critical	Internal service authentication	Auth / Access	Remediated
2	Critical	Transaction submission controls	Auth / Integrity	Remediated
3	High	User confirmation for irreversible actions	UX Safety	Remediated
4	High	Input validation and size controls	Validation / DoS	Remediated
5	Medium	Information disclosure in error responses	Info Leak	Remediated
6	Medium	API credential isolation	Secrets Mgmt	Remediated

4. Finding Details

Finding 1 — Internal Service Authentication [Critical]

The backend transaction-building service lacked authentication. Any process able to reach the service could invoke privileged endpoints. A shared-secret authentication mechanism was implemented: all mutating requests now require a cryptographically random API secret transmitted via a dedicated header. Requests without a valid secret are rejected before reaching any business logic. Read-only health and status endpoints remain accessible for monitoring.

Finding 2 — Transaction Submission Controls [Critical]

The transaction submission endpoint accepted arbitrary serialized transaction data for on-chain submission. While the on-chain validator prevents unauthorized fund movement, the endpoint could be used to relay unrelated transactions through the project's infrastructure. A server-side transaction registry was implemented: only transactions previously built by the service (identified by hash, with a time-limited validity window) are accepted for submission. Unrecognized transactions are rejected.

Finding 3 — User Confirmation for Irreversible Actions [High]

The surrender action — which permanently and irreversibly removes legacy assets from the user's wallet — was initiated with a single button click and no confirmation step. A two-phase confirmation flow was implemented: users first see the action button, then a clearly marked warning panel stating the action is irreversible, displaying the exact amount of cMATRA to be received, and requiring an explicit "Confirm Surrender" click (with a "Cancel" option) before the transaction is initiated.

Finding 4 — Input Validation and Size Controls [High]

Several API endpoints accepted inputs without sufficient validation of format, length, or size. Oversized payloads or malformed inputs could cause unnecessary resource consumption. Comprehensive validation was added at every layer:

- Cardano address validation: prefix, character set (bech32), and length bounds
- Transaction CBOR: maximum size limit, hexadecimal format enforcement
- Asset lists: capped at the maximum number of eligible merger assets
- Pydantic model constraints on the backend service enforce all of the above server-side

Finding 5 — Information Disclosure in Error Responses [Medium]

Error responses from the transaction-building service included raw exception messages that could reveal internal file paths, library versions, or configuration details. Error handling was updated to log full diagnostic information server-side while returning only generic, user-safe error messages to API callers.

Finding 6 — API Credential Isolation [Medium]

A blockchain data provider API key had a fallback configuration path that could result in the key being bundled into client-side JavaScript. The fallback was removed; the key is now exclusively resolved from server-only environment variables, ensuring it is never exposed to the browser.

5. On-Chain Validator Security

The surrender pool validator is a parameterized Plutus V3 spend script written in Aiken. It enforces two invariants:

1. **Authorization** — Every pool UTxO spend requires a cryptographic signature from the designated administrator key (verified via `extra_signatories`).
2. **Time-lock** — During the redemption window, only *ProcessSurrender* operations are permitted (transaction validity must fall entirely before the deadline). After the window closes, the administrator may reclaim remaining funds via *AdminWithdraw* (validity must fall entirely after the deadline).

Validator test coverage: The validator includes on-chain unit tests for all six combinations of signer (admin / non-admin) × timing (before / after deadline) × redeemer (*ProcessSurrender* / *AdminWithdraw*), plus a datum-robustness test. All pass. A separate red-team test suite exercises these scenarios against a deployed preprod instance.

Cardano's extended UTxO model provides inherent protection against several classes of attack: each UTxO can only be spent once per transaction, preventing double-spend and replay attacks. Transaction outputs are deterministic — any modification to amounts, addresses, or metadata invalidates all existing signatures, making transaction tampering infeasible.

6. Two-Party Co-Signing Flow

The merger portal uses a two-party co-signing architecture for surrender transactions:

1. The user connects a CIP-30 compatible Cardano wallet and the portal scans for eligible legacy assets via server-side blockchain queries.
2. The user initiates a surrender. The server builds the full transaction (pool input, user outputs, quarantine routing) and signs it with the administrator key.
3. The partially-signed transaction is returned to the frontend. The user's wallet displays the transaction details for review and adds the user's signature.
4. The fully-signed transaction is submitted to the Cardano network.

This design ensures that:

- **The user retains custody at all times.** Legacy assets are spent directly from the user's wallet in a single atomic transaction — they are never transferred to an intermediary.
- **The user can review before signing.** The wallet displays the full transaction (what leaves, what arrives) before requesting approval.
- **Neither party can act alone.** The server cannot move user funds (lacks user signature). The user cannot drain the pool (lacks admin signature and on-chain authorization).
- **Transactions are tamper-proof.** Modifying any field (amounts, recipients, assets) after the server signs invalidates the server's signature and the on-chain validator rejects the transaction.

7. Additional Security Controls

Control	Description
Rate Limiting	All API endpoints enforce per-IP request rate limits to prevent abuse and resource exhaustion.
CORS Policy	Cross-origin requests are restricted to the official Flux Point Studios domain.
Access Gating	The portal is gated behind an access credential during the pre-launch phase, limiting exposure during testing.
Search Engine Exclusion	The portal page includes <code>noindex</code> , <code>nofollow</code> directives to prevent premature indexing.
Server-Side Scanning	Wallet asset scanning is performed server-side to keep blockchain API credentials out of client code.

Fixed Rate Table	Redemption rates are fixed at publication and cannot be altered during the 6-month window, preventing rate manipulation.
Preprod Rehearsal	The full surrender flow was rehearsed on Cardano preprod testnet (9/9 stages passed) including red-team scenarios.

8. Conclusion

The cMATRA Token Merger Portal has undergone a thorough security review covering the full technology stack — from the on-chain Plutus V3 validator through the backend transaction service to the user-facing web application. Six findings were identified and all six have been remediated.

The system implements defense-in-depth: the on-chain validator enforces cryptographic authorization and time-lock controls; the backend service authenticates callers, tracks transaction integrity, validates all inputs, and limits request rates; and the frontend provides clear warnings and requires explicit confirmation before irreversible actions.

Assessment: All identified vulnerabilities have been resolved. The cMATRA Merger Portal meets the security requirements for public launch.